Fluxos de Comunicação

Fluxos permitidos e bloqueados

Status	Origem	Destino	Protocolo / Porta	Finalidade
Permitido	Cliente externo	AWS WAF / Application Load Balancer (ALB) público	HTTPS / TCP 443	Permitir acesso seguro à aplicação pela internet, com proteção das requisições e distribuição do tráfego.
Permitido	Application Load Balancer (ALB)	Instâncias EC2 da aplicação/API (`SG-APP`)	HTTP / TCP 8080	Encaminhar as requisições às instâncias responsáveis pelo processamento da aplicação.
Permitido	Instâncias EC2 da aplicação/API (`SG-APP`)	Amazon RDS em sub-rede privada (`SG-DB`)	TCP 5432	Consultar e armazenar os dados da aplicação, permitindo acesso somente a partir das instâncias autorizadas.
Permitido	Instâncias EC2 da aplicação/API	Amazon S3, por meio de VPC Endpoint	HTTPS / TCP 443	Enviar e recuperar arquivos com acesso controlado, sem disponibilizar o bucket publicamente.
Permitido	Instâncias EC2 em sub-redes privadas	Internet, por meio do NAT Gateway	HTTPS / TCP 443, quando necessário	Permitir conexões de saída necessárias ao funcionamento da aplicação, sem expor diretamente as instâncias privadas.
Permitido	Administrador autorizado	VPC por meio do AWS Client VPN	VPN / protocolo e porta conforme configuração	Estabelecer acesso administrativo seguro à rede privada, com autenticação multifator (MFA).
Permitido	Administrador autorizado pela VPN	Instâncias EC2 da aplicação/API	SSH / TCP 22	Permitir manutenção dos servidores por meio de acesso administrativo autorizado.
Permitido	Instâncias EC2 da aplicação/API	AWS Secrets Manager, por meio de VPC Endpoint	HTTPS / TCP 443	Recuperar segredos e credenciais necessários ao funcionamento da aplicação, conforme as permissões IAM concedidas.
Permitido	Recursos da VPC	Amazon CloudWatch, por meio de VPC Flow Logs	Serviço gerenciado AWS	Registrar informações sobre o tráfego de rede para monitoramento e análise.
Permitido	Chamadas de API da conta AWS	AWS CloudTrail	Serviço gerenciado AWS	Registrar atividades e chamadas de API da conta para auditoria.
Bloqueado	Internet	Instâncias EC2 da aplicação/API	Acesso direto de entrada não autorizado	Impedir que os servidores da aplicação sejam acessados diretamente pela internet, fora do ALB.
Bloqueado	Internet	Amazon RDS	Todas as portas de entrada públicas	Impedir acesso direto ao banco de dados pela internet.
Bloqueado	Internet	SSH das instâncias EC2	TCP 22, acesso direto da internet	Impedir a administração direta dos servidores pela internet; o acesso administrativo ocorre por meio da VPN e de origens autorizadas.

Status	Origem	Destino	Protocolo / Porta	Finalidade
Bloqueado	Internet	Amazon S3	Acesso público ao bucket	Evitar acesso não autorizado aos arquivos armazenados.
Bloqueado	Instâncias não autorizadas	Amazon RDS	TCP 5432	Permitir acesso ao banco somente a partir do grupo de segurança autorizado da aplicação.
Bloqueado	Origens não autorizadas	Instâncias EC2 da aplicação/API	Portas não permitidas pelas regras de segurança	Restringir o acesso aos servidores às origens autorizadas.
Bloqueado	Usuários ou serviços sem permissão	AWS Secrets Manager	Acesso não autorizado	Proteger as credenciais e os segredos utilizados pela aplicação.

Observações

- O Amazon RDS permanece em sub-redes privadas, com acesso restrito às instâncias autorizadas da aplicação.
- O AWS Client VPN permite acesso administrativo seguro aos recursos internos, com autenticação multifator (MFA).
- O NAT Gateway permite conexões de saída das sub-redes privadas, sem disponibilizar acesso direto da internet às instâncias.
- O Amazon S3 utiliza acesso controlado por políticas e VPC Endpoint, mantendo o bloqueio de acesso público habilitado.
- Os VPC Flow Logs permitem monitorar o tráfego de rede por meio do CloudWatch, enquanto o CloudTrail registra atividades e chamadas de API da conta AWS.
- As permissões do IAM seguem o princípio do menor privilégio, concedendo a usuários e serviços somente os acessos necessários aos recursos da arquitetura.